Vibe-Audit · Rapport de Sécurité Express

Évaluation de sécurité passive pour applications web & stacks IA

DÉMO · application et données fictives

CIBLE	DATE D'AUDIT	AUDITEUR
leadflow-demo.example	13 Octobre 2026	Kreesten Agboton

VULNÉRABILITÉS CONFIRMÉES (4 CONSTATS RÉELS) — 2 ÉLEVÉES · 1 MOYENNE · 1 FAIBLE

2 Élevées (50%) | 1 Moyenne (25%) | 1 Faible (25%)

CONTRÔLES SANS ANOMALIE
4 vérifiés conformes

SYNTHÈSE DÉCIDEUR

L'audit passif de l'environnement **leadflow-demo.example** révèle deux failles d'importance élevée permettant l'accès anonyme aux transactions clients et l'exposition d'une clé API d'envoi d'emails.

Méthode passive appliquée : aucune tentative d'intrusion n'a été menée. Les sessions utilisateurs (JWT) sont conformes. *Les composants Stripe n'ont pas été évalués dans cette mission (hors périmètre).*

PÉRIMÈTRE D'ÉVALUATION

Domaine testé	Méthode	Statut
Supabase RLS (Orders)	API REST anonyme	Constat Élevé
Bundles JS / Clés API	Analyse statique frontend	Constat Élevé
Sessions Utilisateurs	Contrôle JWT & cookies	Examiné conforme
Infrastructure Stripe	Non évalué dans cette mission	Hors périmètre

3 ACTIONS PRIORITAIRES

1. **Activer la Row Level Security sur `orders` (SEC-01)**
   Bloque l'accès public direct aux montants et emails des commandes (Détail page 2).

2. **Isoler la clé secrète Resend dans une Edge Function (SEC-02)**
   Élimine le risque d'usurpation d'identité sur vos envois d'emails transactionnels.

3. **Durcir les en-têtes CSP et X-Frame-Options (SEC-03)**
   Protège l'interface cliente contre l'intégration en iframe et le détournement de clics.

Remédiation : La fiche en page 2 détaille la preuve technique, le prompt IA testé et les critères de validation.

ÉLEVÉ | Constat confirmé

SEC-01 : Absence de Row Level Security (RLS) sur la table des commandes

`supabase/schema:orders`

`Test : API REST, accès anonyme`

1. IMPACT MÉTIER

Fuite de données transactionnelles clients

La table `orders` est lisible sans filtrage par utilisateur. Tout visiteur muni de la clé publique anon peut extraire l'historique complet des commandes, adresses emails et montants encaissés.

2. PREUVE TECHNIQUE REPRODUCTIBLE

CAPTURE : 13/10/2026 15:30 UTC — GET REST API · 200 OK

```
# Requête passive curl via la clé publique anon exposée côté client
curl -i -s "https://leadflow-demo.example/rest/v1/orders?
select=id,customer_email,amount&limit=2" \
  -H "apikey: eyJhbGciOiJIUzI1NiIsInR5cCI***"

# En-tête HTTP certifiant le nombre total d'enregistrements exposés :
HTTP/1.1 200 OK
Content-Range: 0-1/142
[
  { "id": "ord_812", "customer_email": "m.***@gmail.com", "amount":
4900 },
  { "id": "ord_813", "customer_email": "agence.***@pro.fr", "amount":
12900 }
]
# Constat formel : 142 lignes accessibles publiquement sans session
active
```

3. REMÉDIATION IMMÉDIATE

Correction proposée

CIBLE : LOVABLE / BOLT / CURSOR / SUPABASE SQL — PROMPT PRÊT À COLLER

```
-- Hypothèse : la table 'orders' possède une colonne 'user_id' liée à
auth.users.id
Dans Supabase, active la politique Row Level Security (RLS) sur la table
'orders' :

ALTER TABLE orders ENABLE ROW LEVEL SECURITY;

CREATE POLICY "Lecture réservée au propriétaire"
ON orders FOR SELECT USING (auth.uid() = user_id);

CREATE POLICY "Insertion réservée au propriétaire"
ON orders FOR INSERT WITH CHECK (auth.uid() = user_id);

CREATE POLICY "Modification réservée au propriétaire"
ON orders FOR UPDATE USING (auth.uid() = user_id);
```

4. Critères de Validation Post-Déploiement

- ○ **Test 1 (Après correction) :** Rejouer la commande curl avec la clé anon. Le serveur doit renvoyer un tableau vide `[]` ou un code HTTP 401/403.
- ○ **Test 2 (Session utilisateur) :** Se connecter avec un compte client : vérifier que ses commandes personnelles restent visibles sans anomalie.
- ○ **Re-contrôle J+14 :** Prestation éligible au protocole de vérification gratuite après mise en production réelle des correctifs.